

Clariva CFO - Information Security Policy

Owner: Anderson Torres (Owner / Security Lead)

Contact: eanderson.torres@gmail.com

Effective date: 2026-06-09

Review cadence: Reviewed at least annually and on any material architecture change.

1. Purpose & Scope

This policy documents the security controls Clariva CFO operationalizes to identify, mitigate, and monitor information-security risks. It covers the Clariva CFO web application, its serverless API, its database, and all third-party integrations (Plaid, Anthropic, Supabase, Vercel, Square). Clariva CFO is a bookkeeping and financial-intelligence platform for restaurant operators that ingests bank transactions (via Plaid) and POS data to produce ledgers, P&L, cash-flow, and tax-ready reports.

2. Data Classification

- Secret (Plaid access tokens, API keys, service-role keys): server-side only, never sent to the browser.
- Sensitive (bank transactions, balances, ledger data): encrypted in transit and at rest, access scoped per tenant.
- Public (marketing pages, app shell): no restrictions.

Clariva CFO does NOT store full card numbers (PAN), online-banking credentials, or government IDs. Bank authentication happens entirely inside Plaid's interface.

3. Secrets Management

- All credentials (PLAID_SECRET, ANTHROPIC_API_KEY, SUPABASE_SERVICE_ROLE_KEY) are stored as server-side environment variables in Vercel and are never exposed to the browser. Client-exposed variables use the VITE_ prefix and carry only non-secret values.
- Plaid access tokens are written to a dedicated table (r7_ledger_plaid_items) protected by Row Level Security that denies the anon and authenticated roles entirely. Only the service_role key, used exclusively inside the /api/* serverless functions, can read them. The browser never receives a bank access token.
- Third-party APIs requiring a secret (Anthropic) are called only through a server-side proxy, never directly from the client.

4. Access Control

- The browser connects to the database with a least-privilege anon key, and every ledger table enforces Row Level Security scoped by tenant_id.
- Elevated database access (the service_role key, which bypasses RLS) is used only in serverless functions, never shipped to the client.
- Plaid beneficial-owner / dashboard access is limited to the company's authorized control person.

5. Encryption

- In transit: all traffic is served over HTTPS/TLS (enforced by Vercel). Global security headers are set: X-Content-Type-Options nosniff, X-Frame-Options DENY, Referrer-Policy strict-origin-when-cross-origin.
- At rest: data is stored in Supabase (managed PostgreSQL) and Vercel, both of which encrypt data at rest by default.

6. Vendor / Third-Party Risk

Clariva CFO relies on SOC 2-compliant infrastructure providers: Supabase (database/auth), Vercel (hosting/compute), Plaid (bank connectivity), Anthropic (AI parsing), and Square (POS). Secrets for each provider are isolated and rotated if exposure is suspected.

7. Monitoring & Logging

- Serverless function errors are logged (Vercel runtime logs) and surfaced for review.
- Plaid item errors are persisted (status, last_error) and shown to the operator so failed connections are visible rather than silent.

8. Incident Response

On suspected compromise, the security lead will: (1) rotate the affected credentials (Vercel env vars and/or Supabase keys), (2) revoke affected Plaid items via the Plaid dashboard, (3) assess scope using logs, and (4) notify affected parties as required. The security contact above is the escalation point.

9. Data Retention & Deletion

- Plaid access tokens are retained only while the bank connection is active. When an item is disconnected or compromise is suspected, the token is revoked via the Plaid dashboard and the row is removed from r7_ledger_plaid_items.
- Transaction and ledger data is retained while the account is active and for as long as required to support bookkeeping and tax reporting (financial records are generally retained for up to seven years, consistent with IRS guidance).
- On account closure or a verified deletion request, the operator can delete the tenant's ledger data from Supabase and revoke all associated Plaid items, after which the data is no longer retained.
- This retention and deletion practice is reviewed at least annually together with this policy.

10. Change Management & Review

Code changes are version-controlled in Git and deployed via Vercel. This policy is reviewed at least annually and whenever the architecture materially changes (e.g., adding a new data source or third-party integration).